

Project 1-5 Flask

Issues to Fix

1. **SQL Injection Vulnerabilities:**
 - All routes use string formatting for SQL queries
 - No parameterized queries
2. **Error Handling:**
 - No try-catch blocks for database operations
 - No validation for input data
 - No proper error responses
3. **Security Issues:**
 - No authentication/authorization
 - Insecure direct object references
 - Plain text error messages might expose sensitive information
4. **Performance Problems:**
 - N+1 query problem in `/orders` endpoint
 - No connection pooling
 - Repeated connection opening/closing
5. **Code Quality:**
 - Inconsistent error responses
 - Missing HTTP status codes
 - Poorly structured JSON responses
 - Typo in database config key (`MYSQL_DATABASE_HOST`)
6. **Functionality Bugs:**
 - POST `/order` doesn't return the created order ID
 - PUT `/order/<id>` doesn't verify the order exists
 - No proper transaction handling for order creation
7. **Missing Features:**
 - No pagination for large result sets
 - No filtering/sorting options
 - Missing DELETE endpoints

Suggested Fixes

1. Use parameterized queries with `cursor.execute(query, params)`
2. Implement proper error handling with try-catch blocks
3. Add input validation using Flask validators
4. Implement connection pooling
5. Use JOINS to avoid N+1 query problem
6. Add proper authentication (JWT or Basic Auth)
7. Implement consistent response structures
8. Add proper status codes for all responses
9. Implement proper transaction handling
10. Add missing CRUD operations